

Narrativa explicativa – Marco GQM + PRAGMATIC para indicadores OWASP 2025 – España

Texto para nota conceptual, presentación a un comité nacional o prólogo de documento técnico.

1. De las vulnerabilidades sueltas a los objetivos nacionales

Durante años hemos contado vulnerabilidades como quien cuenta gotas de lluvia: muchas cifras, poca brújula. El despliegue de NIS2, el refuerzo del ENS y la avalancha de incidentes gestionados por INCIBE han dejado claro que España necesita algo más que indicadores de “cantidad de problemas”: necesita métricas que conecten directamente con objetivos nacionales y decisiones de gobierno.[web:21][web:24][web:60][web:72]

En este contexto, OWASP ofrece un lenguaje común para hablar de riesgos de aplicaciones (Top 10:2025), madurez de programas (SAMM), verificación técnica (ASVS 5.0) y rating de riesgo, mientras que enfoques como GQM y PRAGMATIC aportan la disciplina necesaria para que las métricas no se conviertan en colecciones de números sin alma.[web:2][web:68][web:87][web:95][web:97][web:100]

2. Qué hace GQM por nosotros

El enfoque **Goal–Question–Metric (GQM)** propone algo de una sensatez casi ofensiva:

1. Empiece por definir claramente sus metas (qué quiere lograr y por qué).
2. Formule preguntas concretas cuya respuesta le dirá si avanza hacia esas metas.
3. Solo entonces, defina métricas que respondan a esas preguntas de forma cuantitativa.[web:87][web:95][web:98]

Aplicado al ámbito nacional, esto significa que no basta con medir “cuántas vulnerabilidades tenemos” o “cuántas horas de formación se han impartido”; hay que vincular cada indicador a metas explícitas, como:

- Reducir la exposición a categorías críticas de OWASP Top 10:2025 en servicios esenciales.
- Aumentar la madurez SAMM en gobernanza y verificación por encima de determinados umbrales en sectores regulados.
- Asegurar que las aplicaciones de mayor criticidad alcanzan, como mínimo, ASVS Nivel 2.

Los indicadores M1–M15 se han definido precisamente siguiendo esta lógica: cada uno responde a una meta clara y a un conjunto de preguntas que conectan el dato técnico con el objetivo nacional.

3. Qué añade PRAGMATIC a la ecuación

GQM nos ayuda a diseñar métricas orientadas a objetivos, pero no nos dice si esas métricas son, en la práctica, buenas compañeras de viaje. Ahí entra **PRAGMATIC**, la meta-métrica propuesta por Brothby e Hinson para evaluar indicadores según nueve criterios: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.[web:88][web:91][web:94][web:96]

En la práctica, PRAGMATIC invita a hacer preguntas incómodas sobre cada métrica:

- ¿Dice algo sobre el futuro (Predictivo) o solo describe el pasado con nostalgia estadística?
- ¿Está ligada a riesgos y decisiones que importan (Relevante)?
- ¿Sugiere acciones concretas (Accionable) o se queda en el “y esto nos preocupa mucho”?
- ¿Refleja la realidad (Genuino) o es fácil de maquillar en un Excel optimista?
- ¿Es comprensible para quien toma decisiones (Significativo)?
- ¿Es suficientemente precisa para apoyar decisiones (Preciso), está disponible a tiempo (Oportuno) y no depende en exceso de fuentes interesadas (Independiente)?
- Y, por último, ¿compensa el esfuerzo de obtenerla (Rentable)?

La matriz PRAGMATIC construida para M1–M15 no pretende ser un juicio final, sino un punto de partida razonable: ayuda a identificar métricas “estrella” para cuadros de mando y otras que quizá deban quedarse en un segundo plano.

4. La combinación: GQM para el sentido, PRAGMATIC para la calidad

Juntos, GQM y PRAGMATIC forman un filtro de doble capa:

- GQM asegura que cada indicador OWASP nace de una meta clara, pasa por preguntas explícitas y desemboca en una definición cuantitativa alineada con los objetivos nacionales de ciberseguridad.
- PRAGMATIC evalúa si esa métrica, una vez definida, merece realmente un lugar en el cuadro de mando: si ayuda a anticipar, a decidir y a actuar, sin arruinar el presupuesto ni la paciencia de quienes deben medirla. [web:87][web:95][web:96][web:99]

En el catálogo propuesto, destacan como especialmente sólidas métricas como:

- M2 (activos críticos sin vulnerabilidades A01–A03), por su relevancia regulatoria y su acción inmediata sobre remediación.
- M4 (MTTR de vulnerabilidades Top 10) y M15 (tiempo detección–decisión), por conectar capacidad técnica y gobernanza.
- M9 y M12 (niveles ASVS y defectos en producción), por vincular aseguramiento técnico con experiencia real del usuario y del negocio.
- M14 (riesgo medio OWASP por sector), por su utilidad estratégica en políticas públicas.

5. De la teoría a los instrumentos concretos

Para que este marco no se quede en un bonito ejercicio conceptual, el kit asociado incluye:

- Un marco integrativo GQM + PRAGMATIC que detalla objetivos, preguntas y definición de cada indicador M1–M15.
- Una matriz PRAGMATIC completa, con puntuaciones y comentarios por criterio.
- Una plantilla de Excel que implementa el cálculo del Índice Global de Madurez (IGM), subíndices OWASP y un ROI aproximado de seguridad a partir de estos indicadores.
- Una plantilla de reporte ejecutivo en forma de estructura de presentación para que los resultados lleguen a la alta dirección en un idioma que entienda y, sobre todo, en un número de diapositivas que pueda soportar.

Todo ello se apoya en las recomendaciones de OWASP sobre métricas en SAMM y Security Culture, y en las exigencias de NIS2/ENS de una gestión basada en riesgos y evidencias.[web:2][web:68][web:97][web:100]

6. ¿Para qué sirve esto a nivel país?

A escala nacional, la combinación OWASP + GQM + PRAGMATIC ofrece:

- Un lenguaje común entre técnicos, gestores, reguladores y académicos.
- Un conjunto de indicadores seleccionados no por ser fáciles de medir, sino por su capacidad para anticipar, priorizar y justificar decisiones difíciles.
- Un marco flexible que permite ajustar métricas, ponderaciones y umbrales conforme evolucionen las amenazas, las tecnologías y las obligaciones normativas.

En otras palabras, es un intento de que, cuando la próxima ola de incidentes llegue –porque llegará–, España no solo pueda decir cuántas gotas ha contado, sino también hacia dónde está soplando el viento y qué paraguas le conviene abrir.